



ROAD TO HALL OF FAME

Bypass por Validación de Ruta Inicial ´

Actividad 11 · Reporte de laboratorio

Ingeniería en Tecnologías de la Información

Universidad Politécnica de San Luis Potosí

Fundamentos de Ciberseguridad

Mtro. Servando López Contreras

Juan Francisco Ortega Jiménez · Matrícula 184918

25 de septiembre de 2026



Road to Hall of Fame — Bypass por Validación de Ruta Inicial

1. Datos generales del laboratorio

Nombre del laboratorio	File path traversal, validation of start of path
Nivel	Practitioner
Tipo de explotación	Path Traversal / Directory Traversal — bypass de validación del inicio de la ruta
Objetivo del laboratorio	Obtener el contenido del archivo <code>/etc/passwd</code> explotando el parámetro "filename", evadiendo una validación que solo verifica que la ruta comience con la carpeta esperada.
URL del laboratorio	https://portswigger.net/web-security/file-path-traversal/lab-validate-start-of-path

2. Explicación técnica de la vulnerabilidad

A diferencia de los laboratorios anteriores, aquí la aplicación no recibe únicamente el nombre del archivo: transmite la ruta completa a través del parámetro `filename`, por ejemplo `/var/www/images/70.jpg`. Como medida de seguridad, la aplicación valida que el valor recibido comience ("starts with") con la carpeta esperada, en este caso `/var/www/images/`.

El problema es que esta validación solo revisa el inicio de la cadena, sin verificar el resto de su contenido. Basta con que el valor recibido comience exactamente con `/var/www/images/` para que la validación se considere satisfecha, sin importar qué se agregue después de ese prefijo.

Esto permite construir un payload que respeta el prefijo exigido y, a continuación, agrega secuencias de salto de directorios (`"../"`) para escapar de esa carpeta y navegar hasta la raíz del sistema de archivos, accediendo finalmente a `/etc/passwd`. La validación pasa porque la cadena sí comienza con `/var/www/images/`, aunque el resto de la ruta la lleve a un lugar completamente distinto. Esta vulnerabilidad también corresponde a OWASP Top 10 – A01:2021 Broken Access Control.

3. Procedimiento paso a paso

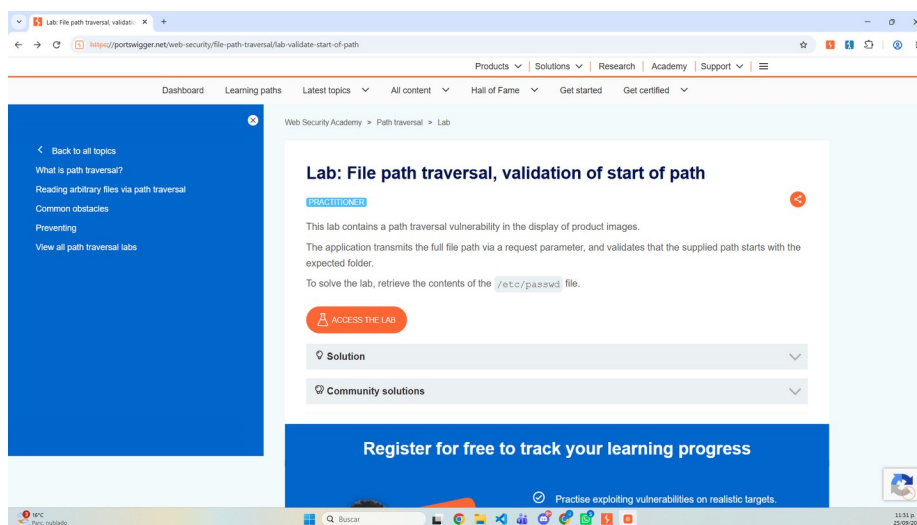
- Abrir Burp Suite Community Edition y crear un "Temporary project in memory" con la configuración por defecto.
- Acceder a la URL del laboratorio e iniciar sesión con la cuenta de PortSwigger; dar clic en "Access the lab".
- En la tienda ("We Like To Shop"), navegar entre los productos para generar tráfico hacia el servidor.
- Ajustar el filtro de HTTP history en Burp: marcar la casilla "Images" en "Filter by MIME type" y dejar vacío el campo "Hide" en "Filter by file extension", ya que el filtro por defecto oculta las peticiones de imagen.
- Con el filtro corregido, localizar en HTTP history una petición GET `/image?filename=/var/www/images/NOMBRE.jpg`. A diferencia de laboratorios previos, aquí el parámetro ya incluye la ruta completa desde el inicio.
- Seleccionar esa petición, clic derecho → "Send to Repeater", e ir a la pestaña Repeater.
- En Repeater, conservar el prefijo `/var/www/images/` exigido por la validación, y agregar a continuación una secuencia de salto de directorios:
`/var/www/images/../../../../etc/passwd`.
- Enviar la petición (Send / Ctrl+Enter) y revisar el panel de respuesta: el servidor devuelve "HTTP/2 200 OK" con el contenido completo de `/etc/passwd`.
- Regresar a la pestaña del laboratorio en PortSwigger, refrescar la página y confirmar que el estatus cambia de "Not solved" a "Solved".

4. Evidencias fotográficas del proceso

A continuación se documenta, en orden cronológico, cada paso realizado durante la explotación del laboratorio, con su captura de pantalla correspondiente.

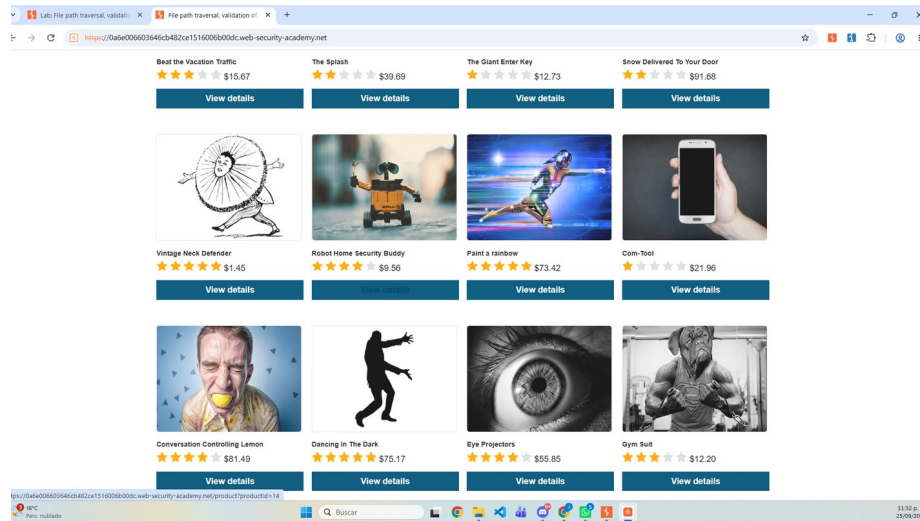
4.1 Página del laboratorio (estado inicial)

Página oficial del laboratorio en PortSwigger, mostrando el nivel "Practitioner", el estado inicial "Not solved" y la descripción del reto: la aplicación transmite la ruta completa del archivo y valida que empiece con la carpeta esperada.



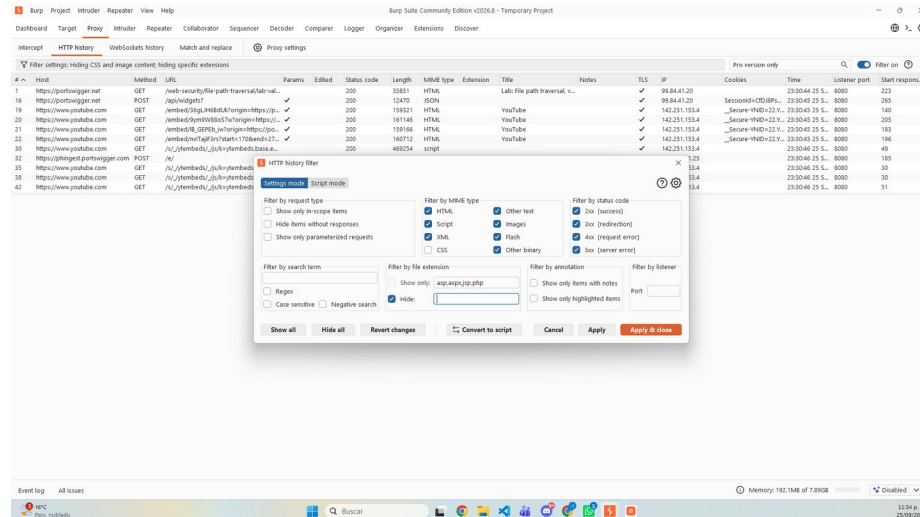
4.2 Generación de tráfico en la tienda

Se accedió a la tienda ("We Like To Shop") y se navegó entre los productos para generar peticiones GET /image?filename= hacia el servidor, necesarias para poder interceptarlas en Burp.



4.3 Ajuste del filtro de HTTP history

Se abrió el diálogo de filtros de HTTP history y se confirmó que la casilla "Images" en "Filter by MIME type" estuviera marcada, con el campo "Hide" en "Filter by file extension" vacío, para poder visualizar las peticiones a archivos de imagen.



4.4 Request interceptado

Con el filtro corregido, se localizó una petición GET /image?filename=/var/www/images/70.jpg en HTTP history. A diferencia de laboratorios anteriores, el parámetro ya incluye la ruta completa del archivo desde el inicio.

The screenshot shows the Burp Suite interface with the HTTP history tab active. A list of intercepted requests is shown, with the first request (GET /image?filename=/var/www/images/70.jpg) selected. The 'Send to Repeater' option is visible in the context menu.

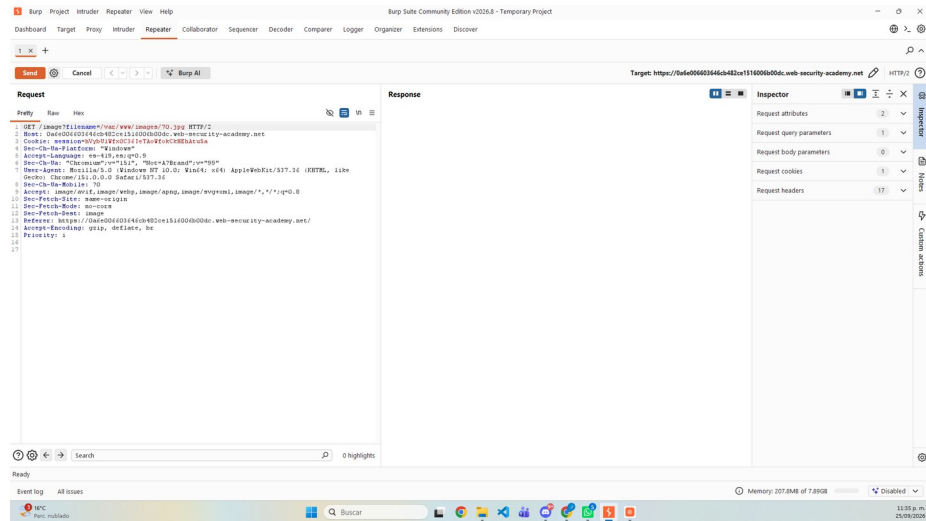
4.5 Envío de la petición a Repeater

Se hizo clic derecho sobre la petición seleccionada y se eligió la opción "Send to Repeater" del menú contextual, para poder modificar y reenviar la petición manualmente.

The screenshot shows the Burp Suite interface with the HTTP history tab active. The selected request is now in the Repeater tab, ready for manual modification and retransmission.

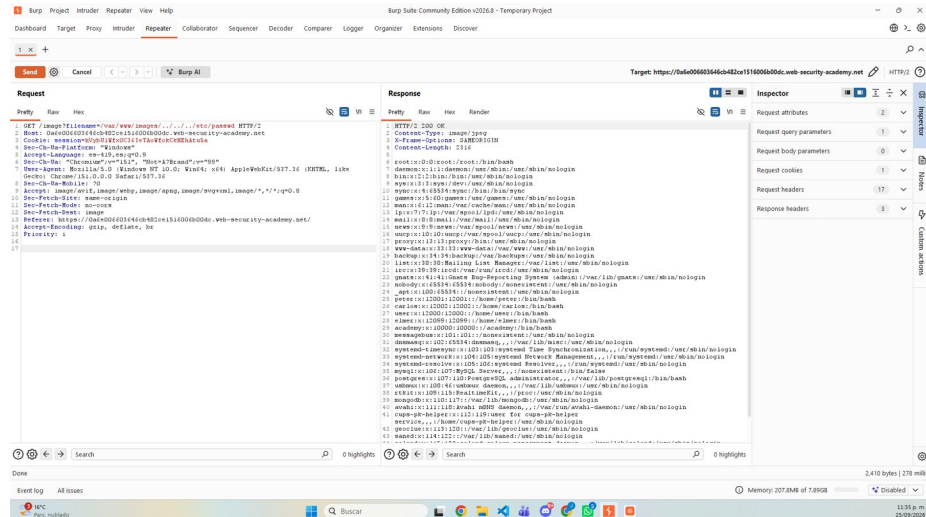
4.6 Petición cargada en Repeater

La petición GET /image?filename=/var/www/images/70.jpg quedó cargada en Repeater, lista para conservar el prefijo exigido y agregar la secuencia de traversal después de él.



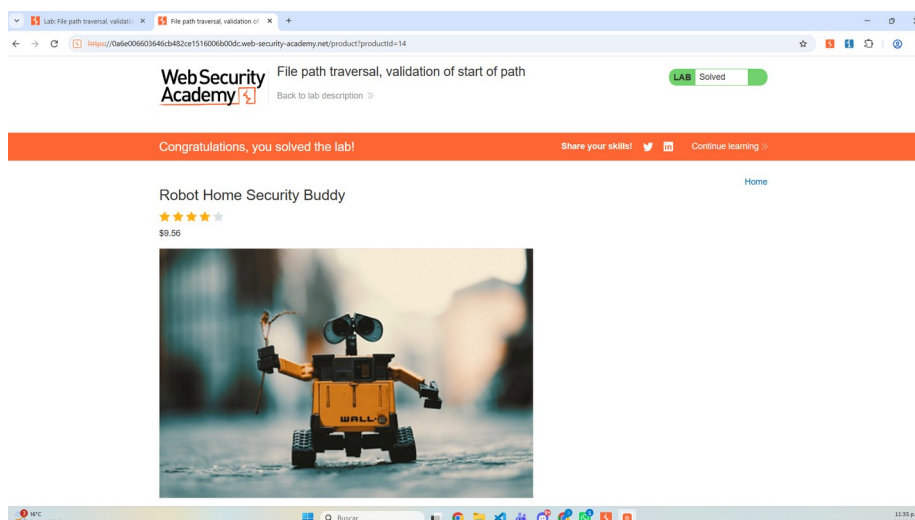
4.7 Payload con prefijo válido y respuesta vulnerable

Se modificó el parámetro `filename` a `/var/www/images/./../etc/passwd`, conservando el prefijo `/var/www/images/` exigido por la validación. Al enviar la petición, el servidor respondió "HTTP/2 200 OK", devolviendo el contenido completo del archivo `/etc/passwd`.



4.8 Confirmación "Lab Solved"

Al regresar a la tienda y refrescar la página, se mostró el banner naranja "Congratulations, you solved the lab!" junto con el indicador de estado en verde "Solved", confirmando que el objetivo de recuperar el contenido de `/etc/passwd` se cumplió exitosamente.



5. Explicación del payload

Payload utilizado: /var/www/images/../../../../etc/passwd

- La primera parte del payload, /var/www/images/, reproduce exactamente el prefijo que la aplicación exige mediante su validación de tipo "starts with", por lo que la petición supera esa comprobación sin problema.
- Inmediatamente después del prefijo válido, se agregan tres secuencias "../", cada una de las cuales sube un nivel en la jerarquía de directorios a partir de /var/www/images/, hasta llegar a la raíz del sistema de archivos ("/").
- Como la validación de la aplicación únicamente revisa que la cadena comience con el prefijo esperado, nunca vuelve a evaluar la ruta después de que las secuencias "../" la resuelven hacia un destino distinto, permitiendo que "etc/passwd" complete la ruta hacia el archivo objetivo.
- El sistema operativo, al procesar la ruta completa, la normaliza siguiendo las secuencias "../" literalmente, resolviendo la ruta real muy lejos del directorio de imágenes que la aplicación creía estar validando.

6. Incidencias durante la práctica

- Filtro de contenido en Burp: al iniciar sesión de trabajo, fue necesario confirmar que el filtro de HTTP history mostrara imágenes ("Images" marcado en "Filter by MIME type"), repitiendo el ajuste realizado en actividades anteriores.
- Identificación del prefijo exigido: a diferencia de otros laboratorios, aquí fue necesario observar primero una petición original completa (filename=/var/www/images/70.jpg) para identificar cuál era exactamente el prefijo de carpeta que la validación exigía, antes de poder construir el payload de bypass.

7. Mitigación recomendada

- Nunca validar una ruta de archivo únicamente por su prefijo ("starts with"); en su lugar, canonicalizar la ruta completa (resolver la ruta real, por ejemplo con funciones como realpath()) y verificar que el resultado final se encuentre dentro del directorio permitido.
- Rechazar cualquier entrada que contenga secuencias de traversal (".../") independientemente de si el prefijo de la ruta parece válido, ya que el prefijo por sí solo no garantiza nada sobre el destino final de la ruta.
- Utilizar listas blancas (whitelisting) de nombres de archivo permitidos dentro del directorio autorizado, en lugar de aceptar rutas completas proporcionadas por el usuario.
- Usar identificadores indirectos (por ejemplo, un ID numérico mapeado internamente a la ruta real del archivo) en lugar de transmitir la ruta del archivo como parte de la petición.
- Aplicar el principio de mínimo privilegio, ejecutando la aplicación con permisos de sistema de archivos restringidos para limitar el impacto de una posible lectura no autorizada.

8. Conclusión

Este laboratorio permitió comprender que una validación basada únicamente en el prefijo de una ruta ("starts with") ofrece una falsa sensación de seguridad: un atacante puede satisfacer ese prefijo literal y, a continuación, usar secuencias de traversal para redirigir la ruta hacia cualquier destino del sistema de archivos. Se reforzó la importancia de validar la ruta final canonicalizada, en lugar de solo una porción de la cadena de entrada.

Referencias

- PortSwigger. (2026). File path traversal, validation of start of path [Laboratorio interactivo]. Web Security Academy. <https://portswigger.net/web-security/file-path-traversal/lab-validate-start-of-path>
- OWASP Foundation. (2021). OWASP Top 10:2021 – A01 Broken Access Control. https://owasp.org/Top10/A01_2021-Broken_Access_Control/